Identity and Access Management Best Practices

VMware Cloud Foundation 9.1

August 2026

vmware by Broadcom

Table of Contents

Disclaimer 4

Part I: Understand the Design 5

- Executive Summary 5
- Why Identity Matters to VCF 5
- How Artificial Intelligence Changes Identity Attacks 6
- A Common Path from the Help Desk to the Hypervisor 6
- What Trust Means in This Design 7
- Scope 7
- Intended Audience 7
- Key Terms 8
- Feedback 8

Part II: Make the Design Decisions 9

- Isolate Infrastructure from Enterprise Identity Providers 9
- Control Internet Exposure 11
- Limit Administration Scope of Infrastructure Identity Providers 11
- Use Identity Federation to Introduce Multi-Factor Authentication 12
- Make Stolen Credentials Insufficient 12
- Severely Restrict Direct ESX and Appliance Management 13
- Design Component-Specific Break-Glass Paths 14
- Restrict Access to vCenter and VCF Operations 14
- Restrict Access to Other Connected Infrastructure Systems 15
- Service Accounts 15
- Retain and Monitor Identity Logs 16
- Rehearse the Procedural Controls 17
- Isolate Backup and Recovery Systems 17
- Common Objections 18
- Where to Start 20
- What Success Looks Like 20

Part III: Implement and Validate 21

- Appendix A: Identity-Provider Deployment Models 21
- Appendix B: Adoption and Operations 22
- Appendix C: Validation and Emergency Access 24
- Appendix D: Logging and Evidence 26

Appendix E: VCF 9.1 Component Summary 27
References 30
Additional Resources 34

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided "AS IS." Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Part I: Understand the Design

Executive Summary

An administrator who signs in to VCF can affect far more than one server. Depending on the role, that administrator may be able to change hosts, networks, workloads, logs, or recovery systems. The identity system behind that sign-in is therefore part of the VCF security boundary.

An organization may connect VCF to the same identity provider used for email, laptops, and everyday business applications. That arrangement is convenient, but it may also give an attacker who controls corporate identity a path to infrastructure administration.

An identity provider is the service that checks a user's identity and applies sign-in rules. The central recommendation is to break the direct path from the corporate provider into VCF. Use a separate provider for infrastructure administration. Do not federate or synchronize the two providers. Give administrators separate infrastructure accounts, even when the same people work in both environments.

Use VCF Single Sign-On (VCF SSO) to connect supported VCF application and application programming interface (API) paths to the isolated provider. Require strong multi-factor authentication (MFA) from managed administrative devices. VCF SSO does not cover every local account, console, appliance interface, or direct VMware ESX login. Each component therefore needs its own tested recovery plan.

The design has several supporting controls:

- Keep routine ESX administration behind VMware vCenter and restrict direct host access.
- Limit who can reach vCenter, VCF Operations, and the other management interfaces.
- Give service accounts only the permissions and credential lifetime their work requires.
- Keep infrastructure account recovery outside the corporate help desk.
- Send identity and management events to remote monitoring, including successful privileged logins.
- Give backup and recovery their own identity, management, and emergency access paths.

Staffing overlap does not require account overlap. One person may have both a corporate account and an infrastructure account. Use a separate account, credential, session, recovery method, and audit trail for each environment. Separate accounts keep credentials distinct and preserve attribution, but they do not provide two-person control. A task that requires two-person approval still requires two different people.

Identity isolation does not replace patching, segmentation, logging, or recovery. It limits one important route into the management plane. It can also make the other known routes easier to monitor.

Why Identity Matters to VCF

Virtualization concentrates administrative power. An attacker who gains broad control of vCenter or the ESX hosts can affect many workloads through one management plane. If the attacker can also reach the backup system, the organization may lose both production services and its normal recovery path.

Attackers reach the management plane in several ways. Some exploit an exposed or unpatched interface. Others use a valid password, session, or access token that was stolen somewhere else. Recent incident data continues to show both vulnerability exploitation and identity compromise as important entry points [1][2][3]. The architecture therefore has to address both. Keep management interfaces off untrusted networks, patch them quickly, and restrict which identity systems can issue or recover administrative access.

One identity-led attack pattern has four stages:

1. The attacker compromises or impersonates a user.

2. The attacker searches for groups, accounts, and systems that lead toward infrastructure.
3. The attacker gains more privilege in a management interface.
4. The attacker changes or destroys workloads, hosts, logs, or backups.

One identity provider often connects those stages. If corporate identity can authenticate to VCF, a corporate compromise may become an infrastructure login. If backup administration uses that same identity system, the compromise may also reach recovery.

Isolation removes that configured trust path. VCF no longer accepts a corporate account through corporate federation or group synchronization. An attacker who starts with corporate identity would need another path. Possible paths include a stolen infrastructure session, a compromised local account, shared administrative authority, or a product vulnerability. The design narrows one route; it does not stop every attack.

How Artificial Intelligence Changes Identity Attacks

Artificial intelligence (AI) does not create a new class of identity attack. It makes familiar attacks easier to prepare and run. An attacker can gather public information, draft a convincing message, translate it, and adapt it to a target with less time and less specialized skill.

Impersonation deserves special attention. A help-desk agent or administrator may receive a call, chat message, email, or video request that appears to come from a coworker. Public profiles can supply names, reporting lines, projects, and the language a real employee would use. Synthetic audio and video can make the request more convincing.

The practical lesson is simple: familiar details are not proof of identity. Caller ID can be spoofed. A manager's name may be public. A voice or face may be synthetic. The Federal Bureau of Investigation (FBI) and Cybersecurity and Infrastructure Security Agency (CISA) have documented this technique. They describe attackers who persuaded support staff to reset passwords or move MFA to attacker-controlled devices [5]. The New York State Department of Financial Services has also warned that deepfakes and voice cloning can be used against identity-verification processes [6].

High-risk recovery and enrollment processes should not depend on one employee deciding whether a caller sounds genuine. Use phishing-resistant authentication, registered administrative devices, known out-of-band contact paths, and multi-person approval where the risk calls for it. Give staff a clear way to refuse or escalate an unusual request without being pressured to make an exception.

AI can also shorten the time between research and attack. Security teams should define an emergency path for actively exploited vulnerabilities and urgent identity changes before an incident begins. The goal is faster, controlled action, with named authority and a usable audit trail.

A Common Path from the Help Desk to the Hypervisor

In 2025, Google Threat Intelligence Group described how UNC3944, also called Scattered Spider, moved from help-desk impersonation to control of virtualization infrastructure [4]. The incident path is useful because it shows how several ordinary administrative processes can be joined into one attack.

A simplified version looks like this:

1. The attacker persuades the help desk to reset a password or enroll another authenticator.
2. The attacker uses the corporate directory and internal documentation to find infrastructure groups and administrators.
3. The attacker uses the compromised corporate identity or its group membership to access vCenter.
4. The attacker changes the vCenter appliance or ESX hosts through privileged management paths.
5. The attacker reaches directory data and backup administration.
6. The attacker disrupts workloads and recovery.

No single control in this design addresses the full sequence. The controls act on different paths.

- Separate infrastructure identity removes corporate group membership as a direct route into VCF.
- Independent account recovery removes the corporate help desk's assigned route for resetting infrastructure credentials.
- ESX lockdown and disabled direct services reduce the host paths available after vCenter access.
- Separate backup identity avoids granting the compromised corporate account an equivalent backup role.
- Remote logging can preserve a second copy after an attacker changes or restarts a management system. The control depends on functional forwarding and a separately administered collector.

These controls still leave risk. An attacker could exploit a product vulnerability, steal a valid infrastructure session, compromise the isolated provider, or act through a malicious administrator. The design is not intended to stop every intrusion. It removes the direct paths identified in this scenario and can make other paths narrower or easier to monitor.

What Trust Means in This Design

Trust means that one system accepts an identity, credential, assertion, or administrative action from another system. Trust is useful. It is also a path that an attacker may be able to follow.

Some trust relationships are obvious. VCF may accept a sign-in from an identity provider. An automation tool may hold an API token. A backup product may have permission to read or change virtual machines. Other relationships are easy to miss, such as a shared service account or a management tool that can change both identity and monitoring.

Trust is not automatically transitive. Suppose system A trusts system B, and system B trusts system C. System C becomes a path to system A only if credentials, permissions, administrative control, or accepted identity claims can cross those connections. A useful trust map therefore records what can cross each boundary, not only which systems are connected.

For each relationship, ask four questions:

- What identity, credential, or control can cross the connection?
- What can that identity do after it crosses?
- Where is the activity logged?
- Can the organization meet the same need with a narrower or separate path?

Appendix B lists the fields to record. Review the map after architecture changes and on a regular schedule. Remove a relationship when no owner can explain why it is still needed.

That is the part of zero trust that matters here. MFA is one control, but the larger goal is to reduce implicit trust and verify the remaining paths. The design may add a broker, device checks, logging, and exception workflows. In return, the organization has fewer hidden ways to reach the management plane.

Scope

The scope is identity and access architecture for VCF 9.1: which identity providers VCF trusts, how administrators sign in, where permissions are granted, and how emergency access works. The isolation model also applies to backup and recovery.

This guidance is not a configuration baseline. Use the *VMware Cloud Foundation Security Configuration and Hardening Guide* for exact settings, ciphers, and values [16]. The design also depends on segmentation, patching, logging, and recovery. Identity architecture is one part of that larger security program.

Some recommendations trade convenience for separation. One identity provider and one sign-in are easier to operate. They also place more administrative reach behind one control plane. Each organization must decide where a separate boundary is warranted.

Intended Audience

The intended readers are infrastructure architects, identity and security teams, VCF administrators, recovery teams, auditors, and technical leaders at organizations that have deployed or are considering VCF 9.1.

Some design principles also apply to earlier releases, but the product names and capabilities are based on the VCF 9.1 generation. If VCF is delivered through an engineered system or third-party hybrid cloud product, confirm the supported identity and management changes with that product's provider.

Key Terms

- **Corporate identity provider:** the directory or cloud identity tenant used for the general workforce and ordinary business applications.
- **Infrastructure identity provider:** a separate provider used only for infrastructure administration. It does not federate or synchronize with corporate identity, and it has separate administrative and recovery paths.
- **Federation:** a trust based on a standard such as Security Assertion Markup Language (SAML) or OpenID Connect (OIDC). Federation lets an application accept a sign-in performed by an identity provider.
- **Synchronization:** automatic copying of users, groups, or attributes from one directory to another.
- **Shared administration:** an account, session, control plane, or recovery path that can administer both identity domains. The same person may work in both domains through separate accounts and sessions. Two-person approval still requires two people.
- **VCF management plane:** the VCF components used to administer the environment, including vCenter, VCF Operations, VMware NSX, and VCF Automation.
- **Infrastructure administrator:** a person or account that can change the management plane or the hosts it controls.
- **Service account or workload identity:** a non-human identity used by automation or an integration. A workload identity is created for that purpose instead of reusing a person's account.
- **Break-glass account:** an account reserved for an emergency when the normal sign-in or recovery path is unavailable or untrusted.
- **Controlled management path:** the restricted route used to reach a management interface, such as a bastion, privileged access service, or dedicated management network.
- **Recovery environment:** the systems used to protect data and restore services after an incident.

Feedback

The source for this document is the repository at https://github.com/vmware/vcf-security-and-compliance-guidelines. Raise feedback through the repository's Issues mechanism or through your account team.

Part II: Make the Design Decisions

Identity isolation depends on linked decisions about provider administration, federation, MFA, direct management paths, service identities, logging, and recovery. A remaining path can defeat the boundary if it gives corporate identity the same effective control over infrastructure.

Isolate Infrastructure from Enterprise Identity Providers

Build a separate identity provider for infrastructure. Do not federate or synchronize it with corporate identity.

Why it matters: A corporate identity compromise should not automatically become an infrastructure compromise.

In a consolidated design, one identity provider handles workforce and infrastructure access. Employees use it for email and business applications. Administrators use it for vCenter and other management tools. One help desk resets all of those accounts.

That design is easy to understand and operate. It also joins two very different risk areas. The corporate provider faces routine phishing, password attacks, device theft, and support calls. If VCF trusts the same provider, an attacker who gains a sufficiently privileged corporate identity may be able to sign in to the management plane.

An isolated infrastructure identity provider removes the configured federation and synchronization paths. Under that design, VCF does not accept corporate users or groups through those paths. Corporate recovery tools receive no role or workflow for resetting an infrastructure administrator. Separate administrative accounts and recovery paths keep the credentials distinct and preserve attribution [15]. A shared administrator, automation tool, or recovery service can still bridge the providers if it has authority on both sides.

Isolation does not require a separate employee for every task. A small organization may need the same identity specialist to support both providers. That person uses a different account and a different authenticated session on each side. Where a process requires approval from two people, staffing overlap does not change the two-person requirement.

The organization still has to manage the boundary. A service account, monitoring tool, provisioning feed, or shared recovery process can quietly connect the two sides again. Inventory each cross-boundary path, give it an owner, and remove it when the business need ends.

Before selecting a design, answer these questions:

- Will the infrastructure provider be a separate cloud tenant or a customer-operated service?
- Who can administer it, and through which accounts and devices?
- How will administrators be added, changed, and removed?
- Which Domain Name System (DNS), time, certificate, network, and database services does it need?
- How will emergency access work when normal identity services are unavailable?
- Which logs will show sign-in, recovery, role, and configuration changes?

The isolated provider adds licensing, infrastructure, lifecycle, monitoring, recovery, and audit work. The amount depends on the provider and the operating model. Appendix A gives bounded deployment examples, and Appendix B lists interim controls for organizations that cannot separate the provider yet.

Dedicated Infrastructure Identity Provider

The infrastructure provider may be a separate cloud identity tenant, a dedicated directory, or a customer-operated SAML or OIDC service. The important point is administrative separation, not where the software runs.

Choose a provider, protocol, and provisioning method that the VCF documentation supports for the deployed build [17]. A product does not become a supported VCF identity provider merely because it implements SAML or OIDC.

Keep the provider's administration, user lifecycle, recovery, and audit trail separate from the corporate side. A cloud tenant should not depend on corporate tenant administrators or corporate recovery. A customer-operated provider should not accept corporate directory accounts or management tools that can rewrite its configuration.

Separate and Distinct Administrative Accounts

Give each administrator a dedicated infrastructure account. Do not derive it from the person's corporate account, reuse its password, or recover it through the corporate help desk.

The same person may hold both accounts. Keep the credentials, MFA enrollment, browser or terminal sessions, recovery methods, and audit records separate. Use a dedicated administrative device for infrastructure work when possible. If one device must support both roles, use a separate browser profile or terminal session for the infrastructure account.

Use temporary elevation where the provider and target component support it. Keep the most powerful credentials in a vault that records retrieval and, where available, the privileged session. Two-person vault retrieval or change approval requires two people, not one person using two accounts.

Independent Multi-Factor Authentication

Keep the infrastructure MFA service independent from corporate MFA. Look beyond the authenticator itself. Ask which service enrolls it, which administrators can change its policy, who can recover it, and which sessions it controls.

An administrator does not always need to carry two physical security keys. One security key based on the Fast Identity Online 2 (FIDO2) standards can hold credentials for different identity providers. Each credential is bound to its own site. The design boundary is in enrollment, policy, recovery, and session control.

Issue more than one approved authenticator to each privileged administrator and store a spare securely. Losing a key should lead to a controlled replacement, not an improvised help-desk reset.

Break-Glass Procedures

Provide an emergency path that does not depend on corporate identity. Administrators need that path when the corporate provider is unavailable, under attacker control, or no longer trusted.

There is no single VCF account that reaches every management surface. An identity-provider emergency account, a VCF SSO emergency API client, a vCenter local account, and an appliance operating-system account solve different problems. Decide which systems responders must reach and maintain a tested path for each one.

Store emergency credentials so authorized responders can retrieve them during an outage, including an outage of the normal vault or privileged access service. Alert on their use, and rehearse the runbook. Appendix C explains the operating model, and Appendix E summarizes the documented VCF 9.1 paths and open tests.

Regular Trust Validation

Small changes can gradually reconnect an isolated environment. An administrator adds a provisioning feed. A service account receives broader permissions. A monitoring tool receives write access. Each change may seem routine, but it can create or expand a trust relationship.

Review federation, synchronization, service accounts, recovery methods, management tools, and cross-boundary network paths on a schedule. Treat every new path as an architecture change. Record its owner, purpose, permissions, logs, expiry, and compensating controls. Appendix B provides an inventory format.

Strict Account Recovery Processes

Keep infrastructure recovery outside the corporate help desk. A support team that resets everyday workforce accounts should not be able to reset a VCF administrator or enroll a new authenticator for that account.

Define the recovery process before it is needed. Name the approvers, identity-proofing method, out-of-band contact path, evidence to retain, and escalation path. Use in-person proofing where it is practical. For remote or after-hours recovery, require a documented high-assurance alternative with more than one independent check.

Treat enrollment of a replacement MFA device as account recovery. A password alone should not authorize a new factor on a privileged account. Provide administrators with spare registered authenticators and a controlled replacement process. If a device is lost, the administrator can use the spare. The team then revokes the missing factor and registers its replacement through the normal process.

Apply the same standard to a managed service provider or vendor that operates the environment. Put the recovery and verification requirements in the contract, identify the provider staff authorized to perform each step, and test the process during an exercise.

Control Internet Exposure

Treat internet exposure as a list of controlled paths, not as an all-or-nothing claim.

Why it matters: Isolation is meaningful only when the organization knows which network paths cross the boundary.

A VCF environment may need external connectivity for software updates, certificate checks, licensing, support, remote administration, or access to a cloud identity provider. A disconnected environment is possible, but it requires a different operating model.

Treat inbound and outbound connectivity as separate design questions.

Do not expose vCenter or ESX directly to the internet or a general-purpose user network. Administrators should enter through a controlled path, such as a bastion, a privileged access service, or a zero-trust network access broker.

Outbound access may be necessary. Allow only the destinations and protocols needed for an approved function. Prefer connections initiated from the management side when the service supports that pattern. Log the connections and review the allowlist when a product or support process changes.

A cloud identity provider is internet-accessible by design. Protect its infrastructure tenant with phishing-resistant MFA, device restrictions, separate administration, and controlled recovery. A customer-operated provider can remain on local management networks, but the customer must operate its availability and recovery dependencies.

Maintain a path inventory for every connection that crosses the boundary. Record the owner, purpose, source, destination, protocol, authentication method, log source, and last review date.

Limit Administration Scope of Infrastructure Identity Providers

Limit the people and systems that can change infrastructure accounts, credentials, or authentication settings.

Why it matters: A system that can create, recover, or elevate an infrastructure identity is part of the privileged access path.

Start with the obvious administrators. Limit who can change users, groups, roles, federation, MFA policy, and account recovery. Then look for systems that have the same power through an integration.

A human resources (HR) feed may create users. A password-reset service may replace a credential. Configuration management may rewrite an identity-provider setting. A monitoring platform may run a remediation action. Each system can become an indirect administrator even when no employee signs in to the identity provider.

Keep corporate provisioning, HR, and password-reset systems from writing into the infrastructure provider. Add infrastructure administrators through a separate process with a named owner and approval record. When the same staff operate both providers, use separate accounts and sessions. Do not let the person requesting privileged access approve the same request when the control calls for separation of duties.

Monitoring requires a distinction between observation and action. A log collector normally needs read-only access. A tool that can change configuration is automation, even if it is sold or operated as monitoring. For each action path, use a scoped service identity and an approved runbook. Apply a time limit where supported, and retain the change record and session or task log.

An identity system that controls access to regulated or contractually governed workloads may be in scope for an audit or assessment. Confirm the scope with the organization's compliance and legal teams.

Cloud identity features can also reconnect the boundary. For example, Microsoft Entra Seamless SSO extends corporate workstation and directory dependencies into sign-in. Administrator Self-Service Password Reset (SSPR) creates a provider-managed recovery route. For a separate infrastructure tenant, avoid Seamless SSO unless the design requires and documents it. Disable administrator SSPR through the tenant authorization policy and use the controlled infrastructure recovery process instead [12][13]. Test the effective tenant and role behavior before rollout.

Audit the chosen provider against its published administrative guidance [11]. Repeat the review after changes to federation, recovery, provisioning, monitoring, or privileged roles.

Use Identity Federation to Introduce Multi-Factor Authentication

Use VCF SSO to connect supported VCF application and API interfaces to the isolated provider. Enforce MFA at that provider.

Why it matters: Federation gives several management applications a common sign-in policy, but it does not cover every administrative path.

VCF SSO uses the VCF Identity Broker. The broker accepts a documented SAML 2.0 or OIDC identity provider. It can provision users through the System for Cross-domain Identity Management (SCIM), just-in-time (JIT) creation, group pre-provisioning, or supported directory synchronization [17][30]. Verify the complete provider, protocol, and provisioning combination for the deployed VCF build.

The broker has two deployment modes. Embedded mode places the broker in the management-domain vCenter. Instance mode deploys it as a VCF management service on VCF Services Runtime. Administrators manage VCF SSO from VCF Operations in either mode [31][32]. Appendix A discusses the surrounding availability decisions.

VCF SSO covers supported federated application and API interfaces. It does not replace every component-local identity source. A vCenter appliance console, an appliance `root` login, or a direct ESX session follows a different authentication path [32][36][40]. MFA and conditional access policy at the external provider do not automatically protect those local paths.

VCF Automation also has a separate tenant identity model. Provider administration can use VCF SSO, while each tenant can configure its own provider. A tenant sign-in is not the same shared management-plane session as provider VCF SSO [45, pp. 1620-1626 and 6768-6774].

Federation also creates a dependency. New federated sign-ins may fail when the provider, broker, DNS, time, certificates, or network path fails. Existing sessions and tokens may continue for different periods. Logging out of one component does not end every other component session [32][34]. Appendix E lists the documented behavior and the tests still required.

During design, decide:

- Which VCF interfaces will use VCF SSO?
- Which provisioning method will create and remove users and groups?
- Which local interfaces remain outside federation?
- How will administrators reach each required component during a provider or broker outage?
- How will the organization end sessions and tokens after an account or role change?

Make Stolen Credentials Insufficient

Assume that an attacker may obtain a password, session, token, or service credential. Design access so that one stolen item is not enough for broad, long-lived control.

Why it matters: An attacker who uses a valid credential may not trigger controls that look only for malware or repeated failed passwords.

Start with phishing-resistant MFA. A phishing-resistant authenticator is bound to the legitimate site. It is designed to reject the simple relay attacks that work against codes and push approvals. FIDO2 security keys, suitable passkeys, and smart cards can provide that property [9]. Short Message Service (SMS), email codes, ordinary one-time codes, and push approvals do not provide the same protection.

For the most powerful accounts, prefer a hardware-bound authenticator with a non-exportable private key. That group includes VCF administrators, identity-provider administrators, emergency-access custodians, and anyone who can recover one of those accounts. Syncable passkeys may be appropriate for other administrators. They do not provide the same hardware-bound assurance described for the National Institute of Standards and Technology's (NIST's) highest authentication level [9].

If the organization still uses push MFA, enable number matching and sign-in context. Those features reduce accidental approval but do not make push authentication phishing-resistant [9][10]. Treat them as an interim or lower-assurance control.

Add device context. Require administrators to use managed devices that meet the organization's security policy. For higher-risk roles, use a dedicated privileged-access workstation or a device with a certificate or attested hardware identity. The goal is to require both an approved identity and an approved administrative device.

Plan for session theft after MFA. Shorten session and token lifetimes where the provider and VCF component support it. Recheck risk and revoke access when supported, but do not assume that one logout ends every component session. Appendix E summarizes the documented behavior. The companion evidence package records the remaining tests.

Put another control in front of destructive work. VCF Automation has documented approval policies for some actions. Other components may need a privileged access management (PAM) approval, controlled bastion, change workflow, or two-person operating procedure. The extra step should produce a record that can be matched to the product event (Appendix C).

Decide which authenticator, device, session, and approval requirements apply to each privilege tier. A read-only operator does not need the same workflow as an identity administrator or someone who can delete recovery data.

Severely Restrict Direct ESX and Appliance Management

Use vCenter for routine ESX administration. Restrict direct host access and each appliance-management interface to the people and networks that need it.

Why it matters: A direct host or appliance login may bypass the federated sign-in, MFA policy, roles, and event trail used for normal application administration.

ESX has more than one administrative path. An administrator can manage a host through vCenter. Direct options include the Host Client, host API, Direct Console User Interface (DCUI), Secure Shell (SSH), and shell. The direct paths do not use VCF SSO [40, pp. 1833-1851 and 2435-2458].

Use lockdown mode to make vCenter the normal path. Keep SSH and shell disabled until a documented support or recovery task requires them. A direct login should be a time-bound exception with an owner, approval, and log review.

Lockdown mode also changes recovery. Normal lockdown can allow a configured user to reach DCUI and exit lockdown when vCenter is unavailable. Strict lockdown stops DCUI. Under strict lockdown, the host may have no direct recovery route unless a qualified exception user already has an enabled SSH or shell path [40, pp. 1833-1851 and 2458-2459]. Test that consequence before choosing strict lockdown.

Management appliances need a different model. vCenter does not administer every appliance. A product login and an appliance operating-system login may use different accounts and grant different rights. For example:

- The vSphere Client and vCenter API use vCenter application identities. Appliance `root` reaches the Virtual Appliance Management Interface (VAMI), console, SSH, and shell.
- VCF Operations has separate application `admin`, operating-system `admin`, and operating-system `root` identities.

- VCF Live Recovery uses vCenter authentication for recovery operations. Its local `admin` and `root` accounts administer the appliance, not the recovery workflow [36][40, pp. 495-496 and 559-561][47, pp. 73-76 and 136-138].

For each component, list the application, API, VAMI, console, SSH, and shell interfaces that exist. Record who needs each interface, how it is reached, how it authenticates, and where its activity is logged. Close or restrict the interfaces that are not part of a current operating or recovery procedure. Appendix E provides the component summary, and the companion evidence package contains the detailed map.

Design Component-Specific Break-Glass Paths

Do not assume that every built-in account is an emergency account. Build a recovery plan for each management surface that responders must reach.

Why it matters: A local account may work on only one part of a product. It may also depend on a console, service, or network path that is unavailable during the same outage.

VCF emergency access falls into three broad groups:

1. **Identity-provider emergency accounts** reach the isolated identity provider. They can use the provider's supported MFA and recovery controls.
2. **The VCF SSO emergency access client** reaches documented Fleet APIs. It has the highest role and largest scope, but it is not a browser or appliance login [35].
3. **Component-local accounts** reach a specific application or appliance interface. Their scope varies by component.

For example, `administrator@<installed-sso-domain>` reaches the vSphere Client and vCenter API. The vCenter appliance `root` account reaches VAMI and the appliance operating system. One does not replace the other. ESX recovery depends on lockdown and service state. NSX `admin`, `root`, and `audit` also have different roles and interfaces [36][40][42][44].

Local accounts do not inherit MFA or conditional access rules from the external identity provider. Protect them in other ways. Restrict the interface and source network. Use a bastion or privileged access service where practical. Store each password under dual-control retrieval, keep it out of routine use, and rotate it through the supported product method. Alert on use only after confirming which event records the login [36][37][38][39].

A local account is not automatically a working break-glass account. Before you count on it, try it in a safe test environment.

- Can you reach the correct login screen when the identity provider or broker is down?
- Does the account have enough access to fix the expected problem?
- Can you recover or rotate its password without the failed system?
- Does the login appear in local logs and in remote monitoring?
- What happens to sessions that were already open?

If any answer is unknown, do not make that account the only recovery path. Appendix C explains how to run the test. Appendix E lists what the VCF 9.1 documentation confirms and what still needs lab work.

Restrict Access to vCenter and VCF Operations

Limit vCenter and VCF Operations to people and services that need them for a current task. Review every interactive and automated path, not only browser access.

Why it matters: These systems expose the inventory, topology, permissions, health, and control points of the environment. Read-only access can still provide useful reconnaissance.

Apply least privilege to people and services. Start with the task, then give the person or service the smallest role and object scope needed to perform it. Review broad roles, inherited permissions, and access that has not been used recently.

Inventory every route into the management plane:

- Direct administrative console access
- PowerCLI and API access
- Automation tools' service accounts
- Backup system access
- Monitoring system access
- Third-party plugin access

Remove routes that have no current owner or purpose. Review plugins as trust relationships because they can add service accounts, permissions, network paths, and upgrade dependencies.

Keep workload administration separate from infrastructure administration. Administrators should normally reach a guest operating system through its own network and identity controls, not through the virtual machine (VM) console in vCenter. Routine server support then does not require a vCenter console entitlement. Network monitoring can observe the guest network path within its configured coverage.

The VM console still has a recovery role. It may be needed for initial installation, a broken guest network, incident containment, or forensic work. Treat console use as an exception with a reason, time limit, owner, and event review.

For each route, record its owner, role, and reachable source networks. Also document how the organization removes the route when the business need ends.

Restrict Access to Other Connected Infrastructure Systems

Apply the same rules to storage arrays, network and fabric switches, backup systems, and hardware management controllers.

Why it matters: Restricting vCenter does little if another management console can still stop hosts, change storage, or delete backups from a general-purpose network.

For each connected system:

- Put the management interface on a restricted network.
- Limit administrators and service accounts to the required roles.
- Avoid corporate directory integration when it reconnects the identity boundary.
- Use unique local recovery credentials and store them securely.
- Require MFA or a controlled bastion where the system supports it.
- Forward administrative events to remote monitoring.

Hardware controllers deserve special attention because they can power systems off, open a remote console, or attach virtual devices. Backup systems need their own identity boundary because recovery teams may need them to restore production after an outage or compromise. Include both in the trust map and recovery exercises.

Service Accounts

Create a separate service or workload identity for each automation purpose. Give it only the permissions, source locations, and credential lifetime that the task needs.

Why it matters: A service account often runs without a person present. Its credential may remain in a script, configuration file, pipeline, or vault for a long time. If the account has broad permissions and its secret is stolen, an attacker may gain the unattended access granted to the service [7].

Do not use a person's account for automation. Create an identity that has a named owner and a clear business purpose. For example, an account that powers virtual machines on and off does not need permission to change identity sources or delete datastores.

Prefer a short-lived token or automatically rotated certificate over a standing password. A non-interactive identity cannot perform human MFA, so compensate with narrow permissions, short lifetime, source restrictions, vaulting, monitoring, and regular review.

Provider controls differ. Microsoft Entra Conditional Access for workload identities can apply location and risk policies to eligible single-tenant service principals, subject to licensing and coverage limits. It does not cover every managed identity, multitenant application, or third-party software service [14]. Record the controls that actually apply to each identity provider and workload type.

VCF 9.1 provides an API-client flow on supported VCF SSO APIs. The client exchanges an API token for a shorter-lived bearer token [33][34]. The ordinary API token defaults to 30 days and can be configured up to 180 days. The bearer defaults to 30 minutes and can be configured up to 480 minutes.

The API token remains the long-lived secret in that flow. Store it in a vault, limit its scope, rotate it, and monitor its use. Do not assume that logout or an owner change immediately invalidates every token. Some bearer and API-client credentials can remain valid until expiry or another documented revocation event [32][34][45, pp. 1169-1171].

Keep an inventory for every non-human identity. Appendix B lists the fields, including owner, purpose, permissions, credential location, source restrictions, last use, and revocation procedure. Document integrations that still require standing passwords as exceptions and give them a rotation plan.

Retain and Monitor Identity Logs

Keep identity and administrative logs long enough to investigate an incident that is discovered late. Monitor successful privileged sign-ins as well as failures.

Why it matters: An attacker using a valid credential may create a normal-looking successful login. A detector that examines only failed-login events has no successful-login event to evaluate.

Start with the events that change access or recovery:

- A privileged sign-in from a new device, address, or location
- A password reset or new authenticator
- A group, role, or permission change
- A new identity provider, API client, token, or service account
- Use of a component-local recovery identity
- A host or appliance console session, reboot, shell, or SSH change
- A backup deletion, retention change, or recovery-policy change

Send the relevant identity-provider and VCF events to remote monitoring. Do not keep the only copy of a management component's events on that component. An attacker with administrative access may be able to change, fill, or remove local logs.

Choose retention through policy. Consider how long an intrusion may remain undiscovered, what investigators need to reconstruct, regulatory obligations, privacy, and storage cost. Mandiant reported an average dwell time of 393 days for one recent espionage campaign [8]. The result illustrates why short retention can leave a major evidence gap.

Do not assume that every local account or appliance action already has a usable remote event. Appendix D lists the known log sources. Appendix E and the companion evidence package mark the audit paths that still need build-specific validation.

Administrative logs can contain employee activity, device details, addresses, and location information. Review collection and retention with legal, privacy, and labor stakeholders, especially across national boundaries.

Rehearse the Procedural Controls

Test the human procedures as deliberately as the technical controls. A tabletop exercise can reveal a missing owner or an unusable recovery step before an actual incident does.

Why it matters: A configuration screen can show that lockdown is enabled. It cannot show whether the help desk will refuse an unsafe reset or whether the on-call responder can retrieve an emergency credential at 2:00 a.m.

Use a concrete scenario. For example, someone who appears to be an administrator asks for an urgent MFA reset. The normal approver is unavailable, and the caller pressures the help desk to make an exception. Walk through who verifies the request, who approves it, what evidence is required, and where the action is logged.

Other useful scenarios include:

- The external identity provider or broker is unavailable.
- A local recovery password is unknown or locked.
- vCenter is unavailable while an ESX host needs emergency work.
- A monitoring tool is found making changes outside its approved runbook.
- The vault, bastion, or remote log collector is unavailable.
- An administrator leaves during an active incident.

Use synthetic personas or approved recordings. Do not imitate a real employee without consent and legal review. Measure whether the process works, not whether an individual can be embarrassed by the exercise.

Run the exercise after material changes to the identity design, recovery tools, provider, or operating teams. Record the failed steps, owners, corrections, and retest date. Apply the same requirements to an outsourced help desk or managed service provider.

Isolate Backup and Recovery Systems

Design backup and recovery with administrative paths that do not depend on production identity or the production management plane. The objective is to give the recovery team a usable path when either dependency is unavailable or untrusted.

Why it matters: Mandiant reported that attackers in its 2025 investigations targeted identity services, virtualization management planes, and backup infrastructure to reduce recovery options. When the same administrative identity is authorized on both production and recovery, theft of that credential can expose both environments. Separate recovery identities remove that shared-credential path. They do not address a stolen recovery credential, a product vulnerability, or an insider with authority in both environments [50, pp. 2 and 6].

Give the recovery environment its own identity domain, administrative accounts, MFA enrollment, secrets store, and emergency access. Do not connect the recovery vCenter to the production identity provider or place it in the production management scope. Test the recovery login while production identity is unavailable.

VCF Live Recovery documents a strict identity-separation design with a separate recovery Identity Broker, identity provider, and recovery-side vCenter credentials [15]. The product interface authenticates through vCenter. Its appliance `admin` and `root` accounts manage the appliance but do not replace vCenter for recovery orchestration [47, pp. 73-76 and 136-138].

The same people may support production and recovery when staffing requires it. They should use separate accounts, credentials, devices or sessions, and runbooks. Any control that requires approval or dual control still needs a second person.

Replication is a narrow exception to the network boundary. Allow only the endpoints, ports, protocols, and connection direction required by the tested design. Use a credential or certificate with no authorization for interactive administration. Monitor the path and document how responders isolate it during an incident.

A short recovery point objective does not guarantee a clean recovery point. Replication can also copy malicious changes or corruption. Keep enough recovery history to select a point before the incident, and validate a recovery candidate in an isolated environment before reconnecting it to production.

Check entitlement feature by feature. Core VCF includes local vSAN snapshots and standalone vSphere Replication with a recovery point objective greater than five minutes. Advanced cyber protection and recovery, remote snapshots, and replication below five minutes require VCF Advanced Cyber Compliance (ACC), a separately licensed advanced service [47, pp. 51-54]. Confirm the entitlement for every other recovery feature named in the design.

Separate change control reduces the chance that one approved update or bulk action reaches production and recovery in the same window. It does not restrict an operator who remains authorized in both environments or an automation identity with the same cross-environment authority.

Regulated organizations should map the design to their own requirements. For example, Article 12 of the EU Digital Operational Resilience Act requires covered financial entities to segregate certain restoration systems from the source system [18]. Applicability and implementation require legal and compliance review.

Before approving the recovery design, answer:

- Which production failures or compromises must the recovery environment survive?
- Which identities and management systems are independent?
- Which replication paths cross the boundary?
- Who can change retention, delete recovery data, or reconnect recovered workloads?
- How will the team operate when production identity, vCenter, DNS, the vault, or normal MFA is unavailable?

Common Objections

Identity isolation changes familiar operating practices. The concerns below should become design inputs, not reasons to skip the discussion.

This Is Not How We Have Done Things

The current design may be stable and well understood. An identity change can disrupt access, automation, and recovery, so plan the migration carefully. Inventory the current dependencies, run a pilot, define rollback steps, and move in stages. Stability alone does not show whether the existing trust boundary still matches the organization's risk tolerance.

We Have Never Had an Incident

A clean incident record does not show how the environment would behave during a valid-credential attack. Such attacks may look like normal sign-ins, and an untested recovery path can appear sound until it is needed. Use configuration review, failure testing, and exercises as evidence instead of treating the absence of a known incident as proof.

Our Administrators Are Not Identity Specialists

Running an identity provider requires skills in authentication, certificates, federation, account recovery, and provider lifecycle. A small joint team can combine those skills with VCF operations knowledge.

An identity specialist from the corporate team may also support the infrastructure provider. Give that person a dedicated infrastructure account that is issued and recovered on the infrastructure side. Personnel overlap does not bridge the boundary by itself. Shared accounts, sessions, control planes, and recovery paths do. Two-person controls still require another person.

This Adds Complexity

It does add another service, lifecycle, recovery plan, and audit surface. The provider may also be simpler than the corporate environment because it supports a smaller population and fewer applications. The net effect depends on the provider, availability model, automation, and staffing. Record both the added work and the trust paths that separation removes.

This Creates a Dependency Problem

Identity depends on DNS, time, certificates, networking, and sometimes a database or load balancer. A customer-operated provider must fit into the startup and recovery sequence without creating a loop.

Document the provider nodes, failure domains, state or database model, load balancer, certificates, DNS, time source, startup order, backup, and recovery procedure. Size it from measured sign-in demand and the capacity required after a node or site failure.

If the provider runs as virtual machines in the management domain, responders need to find them when vCenter or federation is unavailable. Responders also need a direct way to start those virtual machines. A VMware vSphere Distributed Resource Scheduler (DRS) "should run" rule is a preference and may be violated during failure. A "must run" rule can limit VMware vSphere High Availability placement and recovery [20]. Choose the rule after testing the direct-host procedure.

Appendix A gives bounded Keycloak, Active Directory Domain Services, Active Directory Federation Services, `keepalived`, and cloud-tenant examples. They illustrate design questions rather than universal reference architectures.

Offboarding and Onboarding Get Harder

Joining or leaving the infrastructure team becomes a separate lifecycle event. A corporate HR change should not directly create, elevate, recover, or disable an infrastructure administrator.

The process does not have to be informal or entirely manual. It can use a dedicated workflow with named approvers, an infrastructure-side operator, evidence of the request, and a completion check. Keep a current roster and an emergency offboarding procedure for an incident.

This Costs Money We Have Not Budgeted

Budget for licensing, hosting, provider lifecycle, certificates, monitoring, access reviews, account recovery, training, support, recovery testing, and audit evidence. A cloud tenant and a customer-operated provider have different cost profiles. Staffing and support requirements may matter more than virtual-machine resources.

Compare viable designs using the same scope and assumptions. Include the cost of operating the boundary and the expected consequence of leaving corporate identity as a direct administrative path. Do not assume that separation is automatically cheaper or more expensive.

The Isolated Provider Has to Be Highly Available

Availability depends on the operating model.

A provider-operated cloud identity service reduces the infrastructure that the customer maintains. VCF authentication then depends on external connectivity, DNS, the provider control plane, and the isolated tenant configuration. Keep tenant administration and recovery separate from the corporate tenant. Test component-local recovery for a provider or connectivity outage.

A customer-operated SAML or OIDC provider can remain available on local management networks. The customer is responsible for node placement, state and database availability, load balancing, quorum where applicable, certificates, patching, monitoring, backup, disaster recovery, and sizing.

For either pattern, verify the exact provider, protocol, and provisioning combination against the VCF build documentation [17]. Test the loss of a node, site, network path, DNS, time source, and provider control plane.

Where to Start

You do not need to implement the full design in one change window. Start with the controls that remove the broadest identity paths. Then restrict alternate paths and test the affected recovery procedures under their planned failure conditions.

Stage	Initial Work
Establish the identity boundary	Build the separate infrastructure provider, issue separate administrative accounts, require phishing-resistant MFA, remove corporate help-desk recovery, and prepare provider emergency access.
Restrict alternate access	Lock down direct ESX and appliance paths, scope service identities, restrict management networks, and separate recovery administration.
Prove and operate the design	Forward the required events, test each recovery path, review access and trust relationships, and rehearse account recovery and offboarding.

Appendix B provides a staged implementation sequence and interim controls for an environment that cannot establish the complete boundary at once.

What Success Looks Like

A test supports the containment objective when it shows that compromising one identity system does not provide all the access needed to complete the scenario. Interpret the result narrowly. It covers only the identities, interfaces, dependencies, and failure conditions included in the test. It does not show that the design blocks every identity attack or product exploit.

Architecture diagrams show the intended design, but tests show how the controls behave. Define the expected result before each test. Record the observed result and compare it with criteria such as these:

- Attempts by a corporate administrator to create, recover, or elevate an infrastructure administrator are rejected on every in-scope path.
- Each in-scope VCF management interface rejects sign-in attempts from the corporate provider.
- The configured federated path applies the approved MFA and device conditions before granting privileged access.
- Network and role checks restrict direct ESX and appliance paths. Verified events reach remote monitoring where the product provides them.
- Each required emergency account completes its defined task through the intended interface during the tested failure.
- Service identities have a named owner, narrow permissions, a controlled credential, and a working revocation procedure.
- The recovery team completes the defined administrative tasks while production identity is unavailable or untrusted.
- The remote collector retains the required records after the approved restart or compromise simulation.

Treat documented product behavior as a design input, not as operational evidence. A control that has not been tested in the deployed environment remains unverified.

Part III: Implement and Validate

Implementation must be tied to the exact VCF component builds, identity-provider configuration, broker mode, authentication path, and lockdown state in the deployed environment. Record documentary facts separately from observed test results.

Appendix A: Identity-Provider Deployment Models

Deployment choices have two dimensions: which controls the provider supports and who operates it. In every pattern, verify that Broadcom supports the provider, authentication protocol, and provisioning method for the applicable VCF build [17]. Implementing SAML or OIDC does not, by itself, establish VCF interoperability.

Customer-Operated SAML or OIDC Provider

- **Benefits:** local authentication can remain available when external connectivity fails; the organization controls maintenance, data location, dependency placement, and recovery.
- **Trade-offs:** the organization must design and operate provider nodes, state replication, load balancing, certificates, DNS, time, patching, monitoring, backup, and disaster recovery. Use the provider's supported architecture and tested sizing.
- **Isolation requirement:** place the service and its dependencies in infrastructure-controlled failure domains, and keep administration, recovery, and automation separate from the corporate identity environment.

Illustrative Keycloak pattern. An organization can evaluate Keycloak through the generic SAML 2.0 provider path documented for VCF SSO [17]. Keycloak also implements OIDC, but that fact alone does not establish that a Keycloak OIDC configuration is supported with a particular VCF build [21]. The cited Keycloak guidance is pinned to version 26.7.2, released August 19, 2026. A production design might place two or more Keycloak instances in separate failure domains behind a load balancer.

Keycloak state and supporting services require their own availability design. Use a supported highly available relational database for durable realm, user, and client data. Configure distributed caching and cluster discovery for the selected Keycloak version [22][23][24]. Keep DNS, time, certificates, database recovery, and administrative access within the infrastructure boundary.

A redundant Linux load-balancer tier can use `keepalived` for health-based Layer 4 pool membership and Virtual Router Redundancy Protocol (VRRP) endpoint failover [25]. That tier provides client routing and failover for the virtual IP address. It does not replicate Keycloak configuration, sessions, cryptographic keys, or database state. Keycloak clustering and database availability remain separate parts of the design.

Illustrative Microsoft pattern. A Microsoft design can use two or more Active Directory Domain Services (AD DS) domain controllers in separate failure domains for directory and DNS services. AD DS replicates directory data between domain controllers [26].

Active Directory Federation Services (AD FS) availability requires a separate design. Deploy AD FS as a farm of two or more federation servers behind an internal load balancer [27]. The AD FS configuration database can use Windows Internal Database or SQL Server. Select and test the supported database availability design, including SQL Server Always On availability groups where its additional capabilities are required [28]. Load balancing, certificates, service accounts, database recovery, and AD FS farm recovery are separate from AD DS replication.

For either illustration, size for the measured peak authentication rate while one provider node is unavailable. Treat the provider's minimum configuration as a floor, add capacity for maintenance and failure, and validate authentication latency and throughput under the intended failover condition. Record the provider version, node sizes, database design, test workload, and results. A generic virtual CPU (vCPU) or memory value without those conditions is not a production sizing recommendation.

Provider-Operated Cloud Identity Service

- **Benefits:** the provider operates the underlying service infrastructure and can supply geographic service availability without customer-managed identity-provider nodes.

- **Trade-offs:** VCF authentication depends on external network paths, DNS, the provider control plane, tenant configuration, and the contracted service. A provider or connectivity outage can make federated sign-in unavailable.
- **Isolation requirement:** use a separate infrastructure tenant or equivalent administrative boundary. Do not let the corporate tenant, corporate help desk, or corporate recovery process administer or recover infrastructure identities. Maintain tested component-local recovery access.

Illustrative cloud pattern. A separate Microsoft Entra tenant is one provider-operated option listed in the VCF SSO documentation [17]. Configure the authentication and provisioning methods documented for the applicable VCF build. Keep tenant administrators, recovery contacts, privileged accounts, Conditional Access policy, and emergency access independent of the corporate tenant. Test VCF access during loss of the normal internet path and during an identity-provider service interruption. Use the component-local recovery paths instead of assuming federated sign-in remains available.

Dependency and Tenant Boundaries

Isolation does not mean duplicating every supporting service. It means understanding which shared dependencies can transfer administrative control or cause the same outage on both sides. Assess DNS, time, certificate issuance and renewal, databases, load balancers, key management, recovery contact methods, endpoint management, PAM, and administrative network paths.

For each dependency, ask two questions: could a corporate administrator use it to change or recover infrastructure identity, and would its failure remove both normal and emergency access? Separate the dependency when either answer conflicts with the design objective. When a dependency remains shared, record the reason, the permissions involved, the failure behavior, and the compensating control.

For a separate cloud tenant, also examine tenant and subscription administrators, recovery mailboxes and phone numbers, device-management authority, domain ownership, billing administration, and support access. A shared global administrator or recovery mailbox is a direct bridge between the tenants. Shared billing alone may be acceptable when the billing role cannot change identity or recovery settings, but the effective provider permissions must be verified.

Appendix B: Adoption and Operations

Implementation Sequence

A workable sequence from a connected starting point to an isolated one:

1. Inventory identities, groups, service accounts, local accounts, and trust relationships across the VCF components.
2. Map current authentication paths into vCenter, ESX, NSX, VCF Operations, and VCF Automation.
3. Build the isolated infrastructure identity provider and its dependencies (Appendix A).
4. Create and test identity-provider emergency accounts, including their MFA and recovery controls (Appendix C).
5. Inventory, vault, and test each designated component-local recovery identity; configure alerts only after its login event and forwarding path are verified.
6. Configure and test remote audit logging and initial detections for sign-ins, local-account use, privilege changes, broker changes, and rollback actions (Appendix D).
7. Integrate the VCF Identity Broker with the isolated provider.
8. Move a pilot administrator group and validate authentication, authorization, and remote logging.
9. Enforce and test phishing-resistant MFA for the pilot group, then apply it to all infrastructure administrators.
10. Migrate service accounts to scoped, short-lived credentials.
11. Lock down direct host and appliance access.
12. Tune detections after the pilot and cutover without removing the initial coverage.

13. Separate backup and recovery identities from production identities.
14. Test recovery, including recovery while production identity is offline (Appendix C).
15. Decommission the old authentication paths from the corporate identity provider into VCF.
16. Run an access review and a tabletop exercise, then set the recurring cadence.

An organization may begin this transition with identity already integrated: vCenter connected to a directory source, roles granted to directory groups, and automation authenticating with directory service accounts. The transition can be staged if the current provider, protocol, and provisioning combination is supported for the deployed VCF build. The recovery work in steps 4 and 5 provides tested alternatives for the surfaces included in each runbook. Step 6 establishes the audit trail before broker or pilot changes begin. Plan authorization alongside authentication because roles and permissions reference users and groups by identity source.

Check component-specific behavior before the pilot. Existing component-native sources can remain while the broker configuration is piloted, except that VCF SSO overrides an existing external identity-provider configuration on vCenter [32]. Appendix E summarizes VCF SSO scope by component and interface. In particular, the SDDC Manager API supports VCF SSO while the SDDC Manager user interface (UI) does not [32]. Confirm the supported-component list, vCenter Group membership, and mixed-version behavior against the documentation for the deployed build before migration.

Account Lifecycle and Offboarding

Isolation makes infrastructure access a separate lifecycle event. It does not require an informal or fully manual process. A dedicated workflow can accept an approved business event. Do not give corporate HR or identity automation a credential, role, or workflow that directly creates, elevates, recovers, or disables an infrastructure administrator.

Record the request, approver, infrastructure-side operator or automation identity, account change, completion check, and time. Use expiring privileged membership where supported. Set the schedule for access reviews and dormant-account checks based on the organization's risk, staffing, and regulatory needs. Maintain an urgent offboarding path that works during an identity incident.

Help Desk and Credential Recovery

Put the infrastructure recovery boundary in policy and in contracts for outsourced support. Do not grant the corporate help desk a role or recovery workflow that resets infrastructure administrator passwords or authenticators. Require named approvers and more than one independent identity check for privileged recovery. Treat a failed social-engineering attempt as an incident signal, and send recovery attempts to remote monitoring.

Voice or video familiarity is not enough to approve recovery. Use the registered contact and proofing methods selected for the infrastructure environment. A vendor or managed service provider follows the same process and does not receive an informal bypass.

Third-Party Administration

VCF operations can involve platform, hardware, network, storage, backup, and managed-service providers. Give provider personnel identities that are distinct from staff identities and scoped to the customer and task. Prefer approved, time-bound access with session or task recording over standing accounts.

Contracts and runbooks should cover provider MFA, recovery, account expiry, support bundles, remote-support tunnels, emergency support, event retention, and evidence delivery. Where a service provider operates multiple customers, verify that a provider role does not create standing cross-customer access.

Interim Controls

When the organization cannot yet separate the identity provider, reduce the reach of the shared provider while the migration remains open:

- Use dedicated infrastructure accounts in separately administered groups.

- Require phishing-resistant MFA and approved administrative devices for those accounts.
- Remove the ordinary help-desk recovery path.
- Use time-limited elevation where the provider supports it.
- Keep backup and recovery identities separate from production identities.
- Assign authorization in VCF components rather than through broad corporate groups.
- Expand remote logging and alerting for the shared-provider paths.

Record the owner, expiration date, and migration dependency for each interim control. Schedule a review before the control expires. Without that review, a temporary state can remain in place even though it was never accepted as the long-term design.

Working Records

For each trust relationship, record the source, target, direction, protocol, accepted identity or credential, authorization point, owner, purpose, permissions, log source, last review, and removal decision.

For each service or workload identity, record the account name, owner, purpose, systems the identity can reach, privileges granted to it, and privileges it has used. Include the credential type and location, lifetime and rotation, allowed source, last use, and revocation procedure. Keep the records with the architecture and lifecycle process rather than as a separate narrative deliverable.

Appendix C: Validation and Emergency Access

For each important control, define the expected result and how the team will test it. Test the control before production use, after a relevant product or identity change, and on a schedule based on risk. Use a non-production environment for disruptive failure tests. If that is not possible, use an approved maintenance procedure with a named rollback owner.

Use one test record for each control:

Field	What to Record
Owner and approver	The person running the test and the person accepting the result
Scope	Exact VCF component, build, identity-provider configuration, broker mode, authentication mode, and lockdown state
Safety conditions	Test environment or maintenance window, dependencies, stop conditions, and communications
Starting state	Accounts, sessions, tokens, services, routes, and logging that must exist before the test
Action	The failure, login, reset, role change, or administrative operation performed
Expected result	A specific access decision, recovery outcome, event, alert, or denied path
Observed result	What the user, API, component, and monitoring system actually showed
Evidence	Timestamps, event identifiers, log locations, screenshots or command output, ticket, and approval record
Pass or fail	The rule used to decide the result, including any partial or unexpected behavior
Recovery	Rollback steps, actual recovery result, owner for a failed control, and retest date

At minimum, test these conditions. Record where the system accepts or rejects each action and whether the intended task completes:

- Every in-scope path rejects attempts by corporate identities to use, create, recover, or elevate infrastructure identities.
- Every in-scope interface for password or MFA recovery rejects reset attempts that rely on corporate help-desk authority.
- The flow for privileged authenticator enrollment requires the selected checks in addition to a password.
- Each designated component-local recovery identity completes the defined recovery task only through its intended interface and with its intended role.
- Each recovery login produces the expected local event, reaches the remote collector, and triggers the intended alert. An unidentified event or unverified forwarding path is a failed logging test.
- Recovery of a lost administrator authenticator follows the required approval and identity-proofing process.
- Enabling ESX SSH, rebooting the vCenter appliance, creating an API client or long-lived token, and changing a backup-administrator group produce the expected remote events and alerts.
- The recovery team completes the defined administrative tasks while the production identity provider is offline or untrusted.
- The remote log system retains the required vCenter and ESX records after a restart or the approved compromise simulation.

Appendix E identifies the component-specific gaps. The companion evidence package defines the detailed LT01-LT22 scenarios. Do not replace an unresolved documentary statement with a general pass result from a different component or build.

Emergency Access Model

Emergency access is a set of component-specific paths, not one universal account. Maintain a runbook for every application, API, appliance, console, and direct-host surface that responders must reach. Record the identity store, authorized scope, dependencies, custodian, supported reset and rotation method, verified log event, and tested failure scenarios. Appendix E provides the component summary.

Identity-provider emergency accounts. Create named emergency identities in the isolated provider through its documented emergency-access design. Require hardware-bound, phishing-resistant MFA when supported. Keep enrollment and reset outside the corporate help desk. Store spare authenticators and recovery material under dual control. If the same staff administer both identity domains, they use separate accounts and sessions. An action that requires dual control still needs two people.

VCF SSO emergency API client. VCF SSO permits one emergency access client per Identity Broker. The client has the highest role and largest scope, and its token defaults to 180 days. It reaches documented Fleet APIs. It is not a browser login, component-local account, or appliance operating-system credential [35]. Store its token under dual-control retrieval, restrict its source, monitor verified token and API events, and regenerate it after use or suspected exposure. Test every Fleet API operation required by the incident runbook.

Component-local recovery identities. The reviewed VCF 9.1 sources do not document native MFA for the local application and operating-system identities summarized in Appendix E. Restrict their interfaces and source networks. Use PAM or a controlled bastion where practical. Require dual-control retrieval for the most powerful credentials, use unique generated passwords, rotate them through supported product methods, and alert on verified use.

Local application and appliance identities are not interchangeable. For example, `administrator@<installed-sso-domain>` reaches the vCenter application, while appliance `root` reaches VAMI and the operating system [40, pp. 495-496 and 559-561]. VCF Live Recovery appliance accounts do not replace its vCenter application login [47, pp. 73-76 and 136-138].

A locally stored credential does not by itself make an account a usable recovery path. Test whether administrators can reach the interface, sign in, and complete the required task during each planned outage, including loss of the external provider, Identity Broker, vCenter, a network dependency, or the component service.

Custody and Identity Proofing

Use in-person identity proofing where practical. For remote or after-hours teams, define a high-assurance alternative. Examples include two-person video verification combined with a registered hardware key, sealed recovery codes, regional custodians, hardware-key escrow, or PAM recovery with two-person approval. Record which methods the organization accepts and who can authorize each one.

Failure Scenarios

Test the failures that apply to the deployed design:

- Corporate or infrastructure identity provider unavailable or untrusted
- DNS, time, certificate, provider database, or load-balancer failure
- Embedded broker service or instance-mode Identity Broker failure
- vCenter application or appliance unavailable
- ESX disconnected from vCenter under each deployed lockdown and service state
- NSX provider or broker failure under the deployed authentication mode
- Lost authenticator or administrator termination during an incident
- Recovery-site failover or loss of the vault, PAM, bastion, or remote log system
- Incorrect management-network or segmentation change

Record the injected condition, path, account, role, result, session and token state, local event, remote arrival time, rollback, and exact build. A runbook does not pass when it depends on the failed component or lacks a verified audit trail.

Privileged and Destructive Actions

Treat identity changes that alter future access as high-risk actions. Examples include changing MFA or Conditional Access policy, adding an identity provider, modifying an emergency account, rotating a SAML signing certificate, creating an API client, and granting application consent.

Separate routine roles from roles that can delete data, weaken recovery, change an identity source, add or remove a host, enable SSH, or change lockdown. Start with the native permission model. VCF Automation documents approval policies for selected catalog and day-2 actions. Test action coverage, approver mode, expiry, rejection, API behavior, administrator bypass, policy change, and audit correlation before treating the policy as an enforced control [45, pp. 6853-6859].

The reviewed VCF 9.1 sources do not identify a native per-operation approval or step-up control for every destructive action in the other management components. Where the product does not enforce approval, use temporary PAM elevation, a restricted bastion, a change workflow, or a two-person procedure. Record the requester, approver, operator, target, action, time window, approval identifier, product event, result, and rollback. Do not describe a compensating workflow as product-native.

Appendix D: Logging and Evidence

Build the logging plan from the sources each component provides:

- vCenter documents application, authentication-service, and VCF SSO audit records. Validate the sign-in, role, permission, session, VAMI, console, SSH, and recovery events required by the runbooks [40, pp. 625 and 2048].
- ESX documents `/var/log/auth.log`, `shell.log`, `hostd.log`, and `vpxa.log` for different authentication and host-management activity. Configure audit and remote syslog as documented in the *VMware Cloud Foundation Security Configuration and Hardening Guide* for VCF 9.1. Confirm the effective setting and remote arrival on the deployed build [40, pp. 1858-1863][41].
- NSX writes local-user and role changes to its audit log and syslog. Remote forwarding requires configuration [48][49].

- VCF Operations provides User Activity Audit. VCF Automation provides Activity Log. Map the actions and retention that each source covers [45, pp. 5211-5243 and 6649-6859].
- Forward the isolated provider's sign-in, recovery, MFA, role, and configuration events.

Keep a remote copy outside the component's administrative boundary. Do not claim coverage for a local account or appliance action until a test identifies the event and confirms remote delivery. Configure appliance operating-system forwarding only through a supported product or hardening-guide method [16][41].

Focus detection on changes to identity, privilege, recovery, and administrative access:

- New authenticator or password reset for a privileged identity
- Successful use of a designated emergency or component-local identity
- New provider, federation trust, signing certificate, API client, token, service principal, or application consent
- Privileged group, role, permission, or Conditional Access exclusion change
- vCenter appliance console use or reboot
- ESX SSH, shell, lockdown, exception-user, or audit-setting change
- Change to backup-administrator access, backup deletion, retention change, or recovery-policy change
- Privileged sign-in from a new or noncompliant device, or a privileged sign-in that meets another provider-defined risk condition

Track an unverified event or forwarding path as a logging gap. Appendix C defines the evidence needed to close it.

Set retention through an approved policy. Consider incident-reconstruction needs, the time an attack may remain undiscovered, legal duties, privacy, and storage cost. One recent espionage campaign had an average dwell time of 393 days, which illustrates the evidence lost by short retention [8]. NIST Special Publication 800-92 provides general security-log guidance, and NIST Special Publication 800-63B treats identity-record retention as a policy and risk decision [9][19]. Review administrator monitoring with legal, privacy, and labor stakeholders where required.

Appendix E: VCF 9.1 Component Summary

The matrix uses the generally available VCF 9.1.0.0 bill of materials released on May 12, 2026 [29]. It is a documentary baseline, not a report of lab-tested behavior. A statement marked **needs validation** is either absent from the reviewed VCF 9.1 documentation, contradicted by another current source, or dependent on deployment state. Repeat the validation after an asynchronous component patch or a change to the identity provider, broker mode, authentication mode, or lockdown configuration.

Authentication and Management Paths

Component and generally available build	Routine application path	Federation, provisioning, and MFA	Separate recovery path	Documented limit or required validation
VCF Identity Broker 9.1.0.0 b25368698; VCF Services Runtime b25370367 [29]	Embedded mode is configured in the management-domain vCenter. Instance mode is a VCF management service on VCF Services Runtime. VCF SSO is managed from VCF Operations [31][32].	One documented SAML 2.0 or OIDC provider per broker. Provisioning can use SCIM 2.0, JIT, JIT with group pre-provisioning, or periodic Active Directory or Lightweight Directory Access Protocol (LDAP) synchronization. The external provider enforces MFA [17].	One emergency access client is available for Fleet API recovery; it is not a browser login. `vmware-system-user` is a separate appliance operating-system identity [35][36].	No local browser-based broker administrator is documented. The supported VCF 9.1 appliance reset and console procedure is unresolved [36][39].
VMware vCenter 9.1.0.0 b25370922 [29]	Use the vSphere Client or vCenter API with vCenter roles and privileges [40, pp. 559-561 and 2004-2040].	VCF SSO covers the federated application path and uses the broker provisioning methods. MFA is enforced at the external provider [17][32].	`administrator@<installed-sso-domain>` reaches the vCenter application. Appliance `root` reaches VAMI, console, SSH, and shell [40, pp. 495-496, 559-561, and 614-617].	`vsphere.local` is only the default local domain. Appliance `root` does not grant vCenter application authorization [36][40].
VMware ESX 9.1.0.0 b25370933 [29]	Use vCenter for routine host administration. VCF SSO and external-provider MFA apply at vCenter, not at the ESX host [32][40, pp. 559-561 and 1833-1836].	Provision administrators at the provider or local vCenter domain, then grant vCenter permissions on the host or parent object [17][40, pp. 2010-2013].	Direct Host Client and API, DCUI, SSH, and shell use host-local authorization. Host Client is documented for emergency management when vCenter is unavailable [40, pp. 2435-2437].	Normal lockdown can permit DCUI recovery. Strict lockdown can leave no direct path unless a qualified exception user and an already enabled shell or SSH path exist [40, pp. 1833-1851 and 2458-2459].
VMware NSX 9.1.0.0 b25318225 [29]	Use the NSX Manager UI or API. VCF SSO is an additional source; documented component-native sources remain [32][43].	Broker provisioning and external-provider MFA apply to VCF SSO sessions. Local users and NSX roles are managed in NSX [17][42][44].	Local `admin` is an Enterprise Admin application candidate. `root` is available only through the command-line interface (CLI). `audit` is read-only and inactive by default [42][44].	OIDC-only mode can omit the local-authentication choice. Test `/login.jsp?idp=local` during provider and broker outages before relying on it [43].
VCF Operations 9.1.0.0 b25346025 [29]	VCF Operations UI and API support VCF SSO and local application identities [32][45, pp. 5211-5221 and 8436].	Broker provisioning and external-provider MFA apply to VCF SSO. Local application users are separately created and assigned VCF Operations roles [17][45, pp. 5216-5221].	Application `admin`, operating-system `admin`, and operating-system `root` are distinct identities [36].	Release notes say direct vCenter authentication was removed, while the 9.1 administration text still describes it. Validate the deployed build and do not design around that path [45, pp. 5211-5214][46].

Component and generally available build	Routine application path	Federation, provisioning, and MFA	Separate recovery path	Documented limit or required validation
VCF Automation 9.1.0.0 b25370929 [29]	Provider management can use VCF SSO. Each tenant can configure its own SAML, OIDC, or LDAP source [45, pp. 1620-1626, 6698, and 6768-6774].	Broker provisioning and external-provider MFA apply to the provider VCF SSO path. Tenant provisioning and MFA belong to the tenant's provider [17][45, pp. 1620-1626 and 6768-6774].	`admin@System` is provider-local; First User is tenant-local; `admin@vsp.local` and `vmware-system-user` are appliance or runtime identities [36][45, pp. 6698 and 6713].	Provider, tenant, and appliance identities are not interchangeable. The account catalog and password guide conflict on whether a VCF Automation `root` identity is supported [36][37].
SDDC Manager 9.1.0.0 b25371088 [29]	The API supports VCF SSO. The UI does not support VCF SSO [32].	The API can use the broker token path and external-provider MFA. The UI uses a component-local administrative path [32][36].	`admin@local` is documented for API access. `vcf`, `root`, and `backup` are appliance operating-system accounts [36].	The exact supported local UI administrator is unresolved, especially when the installed vCenter authentication domain was customized. `admin@local` is not documented as a UI identity [32][36].
VCF Live Recovery service 9.1.0.0 b25369307; VCF Live Recovery advanced service 9.1.0.0 b25367487 [29]	The product UI and recovery workflow use vCenter authentication and vCenter permissions [47, pp. 136-138 and 160-162].	Federation, provisioning, and MFA occur at the recovery deployment's vCenter and VCF SSO path [15][17][47].	Appliance `admin` reaches VAMI and SSH; appliance `root` reaches the operating system [47, pp. 73-76 and 127].	No product-local replacement for vCenter authentication is documented. Appliance credentials cannot by themselves run recovery orchestration [47, pp. 73-76 and 136-138].
VCF Log Management 9.1.0.0 b25346055 [29]	VCF SSO integration and a local application `admin` are documented. VCF 9.1 material also states that authentication is handled through VCF Operations after upgrade [32][36][45, pp. 530-531].	Broker provisioning and external-provider MFA apply to VCF SSO. Local `admin` does not inherit that MFA [17][36].	Local application `admin` and appliance operating-system `root` have separate scopes [36].	Local `admin` behavior during VCF Operations, provider, or broker failure is unresolved and needs validation [36][45, pp. 530-531].

The VCF 9.1 Identity and Administrative-Access Component Capability Evidence companion contains the detailed local-account, session, token, audit, approval, and failure-test matrices. It also defines LT01-LT22. The companion is a documentary evidence package, not a report of lab-tested behavior.

Use the companion when writing implementation runbooks or evaluating an asynchronous patch. The summary identifies the routine path, the separate recovery surface, and the behavior that still needs to be proved on the deployed build.

References

1. Google Threat Intelligence Group / Mandiant. *M-Trends 2026: Data, Insights, and Strategies From the Frontlines.* March 23, 2026. https://cloud.google.com/blog/topics/threat-intelligence/m-trends-2026 (voice phishing ranked the second most common initial infection vector at 11%, and exploits first at 32%, in 2025 intrusion data).
2. Verizon Business. *2026 Data Breach Investigations Report.* May 18, 2026. https://www.verizon.com/business/resources/reports/dbir/ (software-vulnerability exploitation began 31% of breaches, overtaking stolen credentials).
3. IBM X-Force. *Threat Intelligence Index 2026.* February 25, 2026. https://newsroom.ibm.com/2026-02-25-ibm-2026-x-force-threat-index-ai-driven-attacks-are-escalating-as-basic-security-gaps-leave-enterprises-exposed (exploitation of public-facing applications led initial access at 40% of incidents in 2025, up 44% year over year).
4. Google Threat Intelligence Group / Mandiant. "From Help Desk to Hypervisor: Defending Your VMware vSphere Estate from UNC3944." July 23, 2025. https://cloud.google.com/blog/topics/threat-intelligence/defending-vsphere-from-unc3944
5. FBI, CISA, and partner agencies. "Scattered Spider," Cybersecurity Advisory AA23-320A (updated July 29, 2025). https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a
6. New York State Department of Financial Services. "Industry Letter: Cybersecurity Risks Arising from Artificial Intelligence and Strategies to Combat Related Risks." October 16, 2024. https://www.dfs.ny.gov/industry-guidance/industry-letters/il20241016-cyber-risks-ai-and-strategies-combat-related-risks
7. OWASP Foundation. "OWASP Non-Human Identities Top 10 (2025)." https://owasp.org/www-project-non-human-identities-top-10/2025/top-10-2025/
8. Google Threat Intelligence Group / Mandiant. "Another BRICKSTORM: Stealthy Backdoor Enabling Espionage into Tech and Legal Sectors." September 24, 2025. https://cloud.google.com/blog/topics/threat-intelligence/brickstorm-espionage-campaign (393-day average dwell time, attributed to UNC5221).
9. NIST. *Special Publication 800-63B-4, Digital Identity Guidelines: Authentication and Authenticator Management* (Revision 4). July 2025. https://pages.nist.gov/800-63-4/sp800-63b.html (phishing-resistant authenticators; AAL2 and AAL3; non-exportable keys at AAL3; syncable authenticators do not meet AAL3).
10. CISA. "Implementing Number Matching in MFA Applications." October 31, 2022. https://www.cisa.gov/sites/default/files/publications/fact-sheet-implement-number-matching-in-mfa-applications-508c.pdf
11. NSA and CISA, Enduring Security Framework. "Identity and Access Management Recommended Best Practices for Administrators" (PP-23-0248). March 21, 2023. https://www.cisa.gov/sites/default/files/2023-12/ESF%20IDENTITY%20AND%20ACCESS%20MANAGEMENT%20RECOMMENDED%20BEST%20PRACTICES%20FOR%20ADMINISTRATORS%20PP-23-0248_508C.pdf
12. Microsoft. "Microsoft Entra Seamless Single Sign-On." Last updated April 9, 2025. https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/how-to-connect-sso
13. Microsoft. "Password Policies and Account Restrictions in Microsoft Entra ID," section "Administrator reset policy differences." Last updated May 26, 2026. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-sspr-policy
14. Microsoft. "Conditional Access for Workload Identities." Last updated March 24, 2026. https://learn.microsoft.com/en-us/entra/identity/conditional-access/workload-identity
15. Broadcom. "Enforcing Strict Identity Separation for Zero Trust." VCF Live Recovery 9.1 documentation. Last updated July 13, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/protection-and-recovery/9-1/using-on-premises-

ransomware-recovery/guidelines-for-adding-cyber-recovery-to-an-existing-disaster-recovery-site/enforcing-strict-identity-separation-for-zero-trust.html

16. Broadcom. *VMware Cloud Foundation Security Configuration and Hardening Guide.* Release 910-20260612-01, June 12, 2026. https://github.com/vmware/vcf-security-and-compliance-guidelines/blob/ea455b0c56a27ebe2c944d517d96b5024703c531/security-configuration-hardening-guide/cloud-foundation/9.1/vcf-security-configuration-guide-91-guidance.pdf
17. Broadcom. "Identity Providers and Protocols Supported for VCF Single Sign-On." VMware Cloud Foundation 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/managing-identity-and-access-using-vcf-single-sign-on/what-is/protocols-suported-for--sso.html
18. European Parliament and Council. Regulation (EU) 2022/2554 (Digital Operational Resilience Act), Article 12(3). December 14, 2022. https://eur-lex.europa.eu/eli/reg/2022/2554/oj/eng
19. NIST. *Special Publication 800-92, Guide to Computer Security Log Management.* September 2006. https://csrc.nist.gov/pubs/sp/800/92/final
20. Broadcom. "Understanding VM-Host Affinity Rules: 'Must' (Hard) vs. 'Should' (Soft) Rules." Knowledge Base Article 447700. Published and last modified July 10, 2026. https://knowledge.broadcom.com/external/article/447700/understanding-vmhost-affinity-rules-must.html
21. Keycloak. *Server Administration Guide 26.7.2.* August 19, 2026. https://www.keycloak.org/docs/26.7.2/server_admin/
22. Keycloak. "High Availability Guide: Introduction." Version 26.7.2, August 19, 2026. https://github.com/keycloak/keycloak/blob/26.7.2/docs/guides/high-availability/introduction.adoc
23. Keycloak. "Configuring Distributed Caches." Version 26.7.2, August 19, 2026. https://github.com/keycloak/keycloak/blob/26.7.2/docs/guides/server/caching.adoc
24. Keycloak. "Configuring the Database." Version 26.7.2, August 19, 2026. https://github.com/keycloak/keycloak/blob/26.7.2/docs/guides/server/db.adoc
25. Keepalived Project. *Keepalived README: Load Balancing and High Availability for Linux.* Version 2.4.3, tagged July 20, 2026. https://github.com/acassen/keepalived/blob/v2.4.3/README.md
26. Microsoft. "Active Directory Replication Concepts." Applies to Windows Server 2016 through Windows Server 2025. Last updated May 12, 2025. https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/get-started/replication/active-directory-replication-concepts
27. Microsoft. "Determine Your AD FS Deployment Topology." Applies to Windows Server 2016 through Windows Server 2025. Last updated April 8, 2025. https://learn.microsoft.com/en-us/windows-server/identity/ad-fs/design/determine-your-ad-fs-deployment-topology
28. Microsoft. "AD FS Using SQL Always On Availability Groups." Applies to Windows Server 2016 through Windows Server 2025. Last updated April 8, 2025. https://learn.microsoft.com/en-us/windows-server/identity/ad-fs/operations/ad-fs-always-on
29. Broadcom. "VMware Cloud Foundation Bill of Materials." VMware Cloud Foundation 9.1.0.0, released May 12, 2026. Page last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/release-notes/vmware-cloud-foundation-9-1-0-0-release-notes/vmware-cloud-foundation-bill-of-materials.html
30. Broadcom. "VCF Single Sign-On Architecture." VMware Cloud Foundation 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/managing-identity-and-access-using-vcf-single-sign-on/what-is/sso-architecture.html

31. Broadcom. "Deployment Modes of the Identity Broker," sections "Embedded Mode" and "Instance Mode." VMware Cloud Foundation 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/managing-identity-and-access-using-vcf-single-sign-on/what-is/deployment-models-for-sso.html

32. Broadcom. "Considerations and Prerequisites for VCF SSO." VMware Cloud Foundation 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/managing-identity-and-access-using-vcf-single-sign-on/what-is/points-to-consider-while-setting-up-vmware-cloud-foundation-sso.html

33. Broadcom. "Create API Client and Generate API Token." Applies beginning with VCF 9.1. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/managing-identity-and-access-using-vcf-single-sign-on/managing-api-clients-and-tokens/managing-api-tokens.html

34. Broadcom. "View and Manage Token Lifecycle and Security." Applies beginning with VCF 9.1. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/managing-identity-and-access-using-vcf-single-sign-on/managing-api-clients-and-tokens/view-and-manage-token-lifecycle-and-security.html

35. Broadcom. "Create an Emergency Access Client." Applies beginning with VCF 9.1. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/managing-identity-and-access-using-vcf-single-sign-on/managing-api-clients-and-tokens/create-an-emergency-access-client.html

36. Broadcom. "Accounts in VMware Cloud Foundation," sections "Account Types in VCF," "Local and Application Accounts in VCF," and "Service Accounts in VCF." Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/manage-passwords/accounts-in-vmware-cloud-foundation.html

37. Broadcom. "Default Password Requirements for VCF Components." VMware Cloud Foundation 9.1 documentation. Last updated August 24, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/manage-passwords/default-password-requirements-for-vcf-components.html

38. Broadcom. "Update Passwords for VMware Cloud Foundation Components." VMware Cloud Foundation 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/manage-passwords/update-passwords.html

39. Broadcom. "Reset Local Account Passwords for VMware Cloud Foundation Components." VMware Cloud Foundation 9.1 documentation. Last updated August 24, 2026. Linked procedures must be checked for their product-version applicability. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/fleet-management/manage-passwords/reset-passwords-for-vmware-cloud-foundation-components.html

40. Broadcom. *vSphere in VCF.* VMware vSphere 9.1 documentation. Last updated August 27, 2026. Sections used include "Managing the vCenter," pp. 495-496; vCenter authentication, pp. 559-617; lockdown and shell, pp. 1833-1851; ESX logging, pp. 1858-1863; privileges, pp. 2010-2040; VCF SSO audit, p. 2048; and Host Client and lockdown recovery, pp. 2435-2459. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/vsphere-in-vcf.html

41. Broadcom. "VCF 9.1 Security Configuration Guide Controls." Release 910-20260612-01, June 12, 2026. https://github.com/vmware/vcf-security-and-compliance-guidelines/blob/ea455b0c56a27ebe2c944d517d96b5024703c531/security-configuration-hardening-guide/cloud-foundation/9.1/vcf-security-configuration-guide-91-controls.csv

42. Broadcom. "Managing Local User Accounts." VMware NSX in VCF 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/advanced-network-management/authentication-and-authorization/managing-local-user-accounts.html

43. Broadcom. "Logging in to NSX Manager," sections covering local authentication and OIDC-only mode. VMware NSX in VCF 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/advanced-network-management/authentication-and-authorization/logging-in-to-nsx-manager.html

44. Broadcom. "Role-Based Access Control," sections covering built-in roles and Enterprise Admin. VMware NSX in VCF 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/advanced-network-management/authentication-and-authorization/role-based-access-control.html

45. Broadcom. *VMware Cloud Foundation 9.1.* Consolidated documentation PDF, created June 18, 2026. Sections used include VCF SSO token lifecycle, pp. 1169-1171; VCF Operations identity and audit, pp. 5211-5243 and 8436; VCF Automation identity, token, audit, and approval, pp. 1620-1626 and 6649-6859. https://techdocs.broadcom.com/content/dam/broadcom/techdocs/us/en/pdf/vmware/vcf/vcf-90/vmware-cloud-foundation-9-1.pdf

46. Broadcom. "VMware Cloud Foundation 9.1.0.0 Release Notes," section "Product Support Notes." Released May 12, 2026; page last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/release-notes/vmware-cloud-foundation-9-1-0-0-release-notes.html

47. Broadcom. *Protection and Recovery 9.1.* PDF created August 24, 2026. Sections used include appliance and product authentication, pp. 73-76 and 127-138; permissions and recovery operations, pp. 160-171. https://techdocs.broadcom.com/content/dam/broadcom/techdocs/us/en/pdf/vmware/vcf/protection-and-recovery/protection-and-recovery.pdf

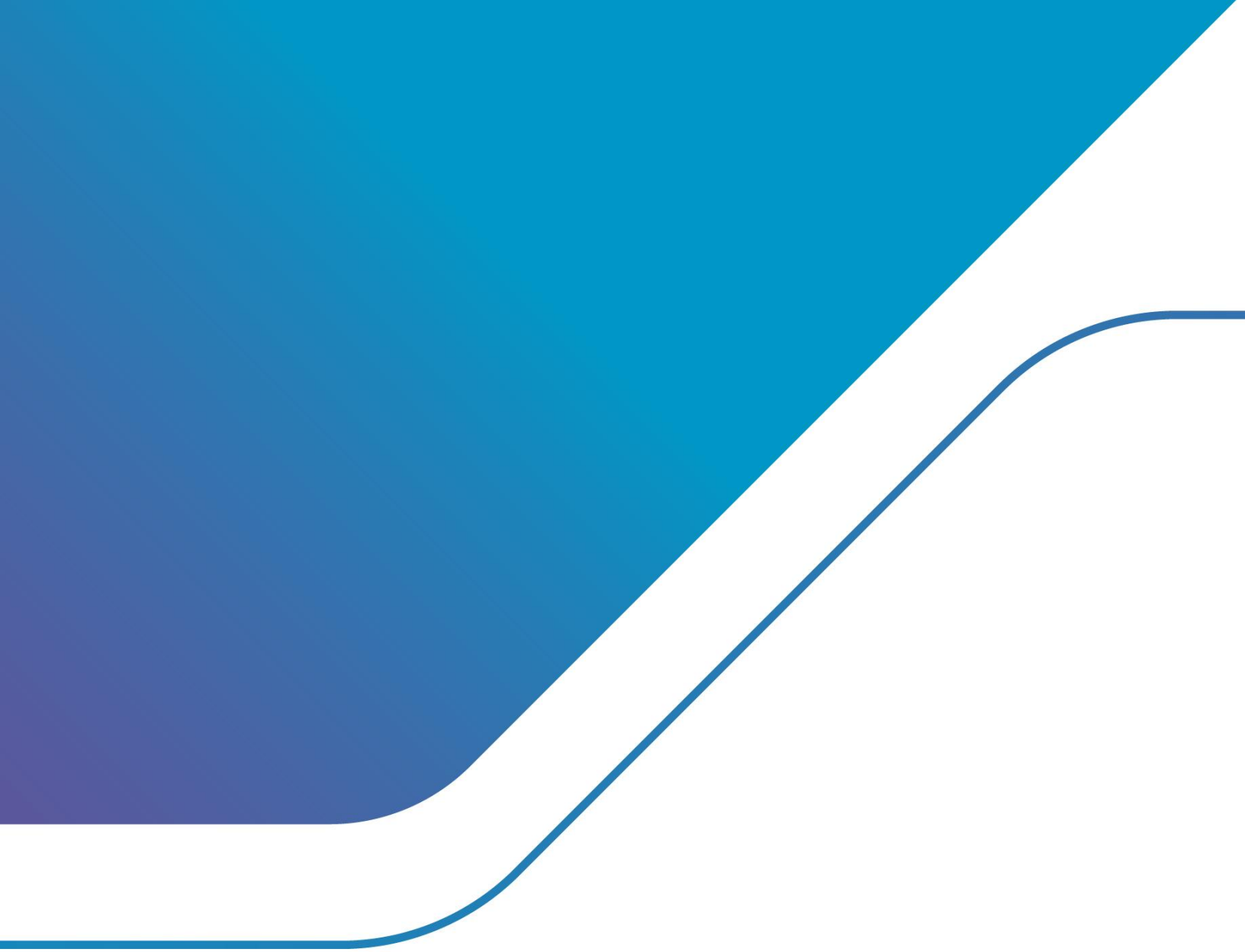
48. Broadcom. "Logging User Account Changes." VMware NSX in VCF 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/advanced-network-management/authentication-and-authorization/logging-user-account-changes.html

49. Broadcom. "Configure Remote Logging." VMware NSX in VCF 9.1 documentation. Last updated August 27, 2026. https://techdocs.broadcom.com/us/en/vmware-cis/vcf/vcf-9-0-and-later/9-1/advanced-network-management/operations-and-management/log-messages-and-error-codes/configure-remote-logging.html

50. Google Threat Intelligence Group / Mandiant. *M-Trends 2026 Report: Executive Edition.* 2026, pp. 2 and 6. https://services.google.com/fh/files/misc/m-trends-2026-executive-edition-en.pdf (observations of attacks on identity services, virtualization management planes, and backup infrastructure to deny recovery).

Additional Resources

- VCF security resources hub: https://brcm.tech/vcf-security
- *VMware Cloud Foundation Security Configuration and Hardening Guide*: https://github.com/vmware/vcf-security-and-compliance-guidelines
- VMware Security Advisories: https://support.broadcom.com/web/ecx/security-advisory
- Broadcom Technical Documentation for VMware Cloud Foundation 9.1: https://techdocs.broadcom.com



vmware® by Broadcom

Copyright © 2026 Broadcom. All rights reserved.
The term "Broadcom" refers to Broadcom Inc. and/or its subsidiaries. For more information, go to www.broadcom.com. All trademarks, trade names, service marks, and logos referenced herein belong to their respective companies. Broadcom reserves the right to make changes without further notice to any products or data herein to improve reliability, function, or design. Information furnished by Broadcom is believed to be accurate and reliable. However, Broadcom does not assume any liability arising out of the application or use of this information, nor the application or use of any product or circuit described herein, neither does it convey any license under its patent rights nor the rights of others.